STUDENT TEAM WEEKLY REPORT

PROJECT / FEATURE	TEAM & MENTOR	WEEK / LEADER
Question Bank & Quiz Engine [Integration — Security & Audit Control; Final Integration Wrap-up]	TEAM ID : 2 FACULTY MENTOR: Mr. Rudragouda Patil	WEEK ENDING: 05/10/2026 STUDENT LEADER: Kartik Manoj.

WORK COMPLETED	CHALLENGES / RISKS	HELP NEEDED
• **Token authentication flow:** Reviewed login → Bearer token (SessionManager, 2-hour rolling session) → Authorization header from sessionSecurity.js → authenticateRequest, which returns 401 or 403. • **Security test script:** test_security_audit_module7.js checks /api/admin/users for 401 (no or bad token), 403 (Author) and 200 (Admin), audit-log retrieval, and a result with 3 tab switches. • **Login protection:** Reviewed BCrypt hashing (PasswordUtil), 5-attempt / 15-minute lockout returning HTTP 429 (LoginRateLimiter), and login, failed-login and logout entries in the PostgreSQL audit_log. • **Audit & anti-cheating wiring:** logSecurityAudit posts to /api/audit-logs for quiz publishing, question edits and bank deletions; student.html detects tab switches (auto-submit with integrity flag at 3) and shuffles questions; client idle timeout is 15 minutes. • **Final wrap-up:** Consolidated the Weeks 6–8 integration status and layer-wise connections (see page 2).	• **Server checks missing:** Token and role checks exist only on /api/admin/users and /api/quiz-results/grade. Question banks, quizzes, results, audit logs and analytics have none; role control elsewhere is client-side. • **Demo tokens:** SessionManager accepts fixed tokens demo_admin_token and demo_author_token, and getAuthHeaders falls back to demo_admin_token, giving admin access to any caller. • **Passwords:** Seeded users have unsalted SHA-256 hashes, not BCrypt. Login also accepts a plain-text match. • **Audit & sessions:** Publish, grading and bank-delete events are kept in memory (client-posted to /api/audit-logs); lockout and sessions reset on restart. • Correct answers reach the browser and are hidden only in the UI; the security script has fixed macOS paths.	• **Decision needed from Backend team**: Before the final demo, should we remove the demo tokens and enforce authentication on all endpoints (needs auth headers on every frontend call), or demonstrate with the current setup and state these limits? • Frontend team to confirm which pages can send the Authorization header on every request.

INTEGRATION AND COLLABORATION	COMMON KPI EVIDENCES
Interfaces Used: POST /api/auth/login and /logout, GET /api/admin/users, GET/POST /api/audit-logs, POST /api/quiz-results/grade, sessionSecurity.js, SessionManager, LoginRateLimiter, AuditLogDAO. **Dependencies (open):** • Backend team — enforce token and role checks on remaining endpoints; remove demo tokens. • Frontend team — send Authorization header on all fetch calls. • Database team — re-hash seeded passwords with BCrypt; persist audit events. **Pipeline Learnings:** Login → token → Authorization header → authenticateRequest → handler → audit_log. Only two endpoints currently sit behind this chain, so most of the pipeline is open.	• **Foundational Behavior:** Lockout after 5 failed attempts for 15 minutes; server session timeout 2 hours, client idle timeout 15 minutes. • **Continuous Integration:** test_security_audit_module7.js starts AppServer and checks 401/403/200; it only runs on the original author's machine paths. • **Instrumentation:** Result records store tabSwitchCount and cheatingFlag; audit entries record user, action and time. • **Collaborative Delivery:** PROJECT_SUMMARY.md consolidates the backend, frontend, database and integration folders.

NEXT WEEK COMMITMENTS	MENTOR RESPONSE
• Owner: Rehearse the full demo flow (login, quiz, grading, analytics, audit) on one machine. • Owner: Run and screenshot the API, load and security test scripts for the report. • Owner: Prepare the answer on known gaps (in-memory data, demo tokens, fixed analytics values). • Owner: Finalise the Integration README with actual endpoints.	